

API contract reference

Client handoff edition

A clear, controlled reference for Bridge and PIMASCOR operations, acceptance, and ownership decisions.

Prepared for	Bridge / PIMASCOR
Edition	2026-08-01
Source	API-CONTRACT.md
Status	Client-facing; infrastructure and source code excluded

Brand reference: bridge-ph.com/about-us/

PIMASCOR API contract

Base path: /api/v1 Contract baseline: REQUIREMENTS-V2.md

Conventions

- JSON requests and responses; decimal money values are serialized as strings.
- Opaque session cookie authenticates; state-changing requests also require X-CSRF-Token.
- List/read routes are role-filtered by the API.
- `expected_version` implements optimistic concurrency. A stale mutation returns 409 and tells the user to refresh.
- Validation errors return 422; unauthorized identity 401; forbidden role/ownership 403; missing resource 404.
- Every response receives a correlation identifier; material actions create audit events.

Identity

The password-start response exposes a development code only outside hosted production mode. Hosted delivery uses Resend. A challenge lasts five minutes, works once, and can be completed by entering the six-digit code or opening the email link. `PUBLIC_APP_URL` is a trusted deployment setting; the API never builds this link from the request Host.

Clients and reference data

Funding sources are controlled data. The DCS payment API rejects arbitrary source names. Only Admin may create/deactivate them; deactivation preserves historical payment snapshots. Names should contain a recognizable source label and, at most, masked last-four account digits.

Sales quotations

GM normally approves or returns. DCS emergency override requires a reason and is audited as an override. Client acceptance is multipart and stores a verified PDF/JPEG/PNG signed quotation privately. New shipment Budget Requests may link only to an accepted quotation with matching client and shipment.

Budget Requests and Additional Budgets

Budget lines include `kind` (BUYING or SELLING) and `classification` (PASS_THROUGH or SERVICE_CHARGE). New shipment requests link to an accepted quotation. Submission moves to Mich review; only a reviewed request enters the GM queue. DCS emergency override requires a reason. A Requester may update only an owned Draft or Rejected record; `expected_version` prevents stale overwrites, and submitted records remain locked.

Consolidated DCS payments

Admin/DCS may mutate. GM/Mich may read. `actions` accepts HOLD, RETURN, RESUME, or NOTE with a reason/note. Payment accepts amount, date, mode, configured source, recipient, external transaction reference, optional note, and expected version. The UI completes payment with a verified PDF/JPEG/PNG proof upload; proof metadata is returned without exposing a public object URL.

Liquidation

- Requester/Admin saves drafts for the Requester's original shipment.
- Submission requires receipt metadata when actual spend is positive.
- Mich/Admin adds return/reimbursement proof, confirms receipt of physical

originals, and closes.

- Non-zero variance closure fails until matching evidence exists.
- Submitted and closed records reject silent edits.

POST /liquidations/{id}/evidence accepts multipart PDF/JPEG/PNG evidence up to 100 MB per file. It validates and hashes bounded chunks, records SHA-256 and size, and uses a managed multipart transfer to private B2 storage. GET /documents indexes signed quotations, payment proof, and Liquidation evidence for authorized staff. GET /documents/{id}/view audits access and streams the object inline with no-store and sandbox headers. Requesters cannot view DCS payment proof. GET /documents/{id}/download is available only to Mich, GM, DCS, and Admin, uses attachment, no-store, and an audit event.

Billing

Mich/Admin creates and edits drafts. The API calculates VAT/CWT from active tax profiles and snapshots rates and amounts per line. POST /billing/{id}/submit moves a draft to Pending Approval. GM and Admin can call POST /billing/{id}/decision. Finalize requires both Approved status and confirmation: "FINALIZE". A finalized record is immutable. Admin-only void requires a reason and preserves the record. A replacement request receives a temporary proposal reference; the official -R# replacement reference is assigned only after GM or Admin approval. It cannot be finalized while the original remains finalized. Credit Memos always require GM or Admin approval before affecting the collectible balance. Requesters see only finalized Billing for their own Budget Requests.

Shipment profitability

GET /dashboard/shipment-profitability?month=YYYY-MM returns role-filtered shipment rows and totals for the selected month. Selling is approved Budget Request selling, actual spending is Liquidation actual total, and profit is selling less actual spending. It also returns margin, Liquidation status, finalized-Billing collection status, outstanding amount, and aging days. Admin, GM, and DCS additionally receive a monthly Request for Payment summary split into OPEX, Marketing, Loan Payment, and Other totals and counts; other roles receive null.

Client Payments and receivables

Receivables and the check/payment register are read-only for Admin/Mich/GM/DCS. Mich/Admin records a Client Payment and allocation list. For a check, check_number is required and may supply the derived external reference; payment_reference is optional. Bank transfers require their external reference. The API validates same-client ownership, finalized Billing status, unique Billing per payment, received-payment ceiling, approved Credit Memos, and outstanding-balance ceiling.

Request for Payment

The endpoint name remains an internal compatibility boundary; the user-facing label is Request for Payment. requested_source is optional/ignored for the actual disbursement decision. DCS selects the source at payment time. New Loan Payments end at DISBURSED; the Admin-only legacy validation endpoint exists solely for records created by the earlier demo and remains provisional pending Bridge Accounting approval. Mich cannot use it.

Health and Admin activity

Health is safe for Caddy/Podman probes and exposes no credential. /incidents creates a user-authorized report; /{incident-id}/report sends an already-protected server reference for investigation. Dismissal is local and calls neither endpoint. /admin/activity is Admin-only and returns summary counts, a Philippine-time daily series, categories, actor summaries, and recent events. It defaults to staff activity; include_admin=true exposes privileged actions that remain recorded. Viewing the monitor is itself audited.

Security rules

- A role check exists on every route; ownership is additionally checked for Requester records.
- Admin is the explicit superuser in the shared role dependency and is accepted by

every protected role gate. It remains ADMIN in responses and audit events and does not bypass record-state, optimistic-version, CSRF, evidence, or confirmation requirements.

- Secrets are read from Podman secret files through *_FILE settings.
- Logs and API errors never include passwords, OTPs in hosted mode, session values, database URLs, Resend keys, or Backblaze keys.
- Rejected password/email-code checks record a generic security event without the submitted secret, identifier, email address, or full bank details.
- Finalization, payment, rejection, void, and closure are POST/PATCH mutations with CSRF and version checks.
- Incident creation and decision require a session and CSRF. A client UUID prevents

duplicate reports. Responses omit technical context; Admin supervision sees only privacy-minimized audit metadata.